

Exercise 4

Type: Vulnerable web app (web challenge — path traversal / file disclosure)

Technical details:

Language / framework: Python + Flask

Runs in a Docker container. Exposed port (host) used in testing: **5023** (visit

<http://localhost:5023/>)

App layout inside container: App root: /app, Uploads folder: /app/uploads (user uploads and extracted ZIP contents go here), Flag file: /app/flag.txt (placed inside the container image; **not** in /app/uploads initially)

How to run web app:

- docker-compose build
- docker-compose up

How to solve:

1. Browse the site and examine pages and source. The site contains built-in library entries with small hints (some encoded text) that point to credentials.
2. **Find credentials** — Using hints in the site, discover:
3. Username: user1234
4. Password: KapteinSabeltann
5. **Login** — POST the credentials at /login (or log in via the site form) to become an authenticated user and reach /my-page.
6. **Discover upload behavior** — On /my-page, try uploading files and inspect generated URLs. The site hints that uploaded files are accessible at /library/app/uploads/<filename> (i.e. they are placed in /app/uploads).
7. **Use a ZIP to declare a server path** — Create a ZIP that contains an entry named ../flag.txt. This entry does not need to exist locally

Example code to create zip:

```
python3 - <<'PY'

import zipfile

with zipfile.ZipFile('exploit_flag.zip','w') as z:

    z.writestr('../flag.txt','')

print('exploit_flag.zip created')

PY
```

Hints:

1. Looking for a password? What is this person's interest?
2. Try uploading some files, take a look at the urls.
3. What kind of files can you upload? Try a .zip file.